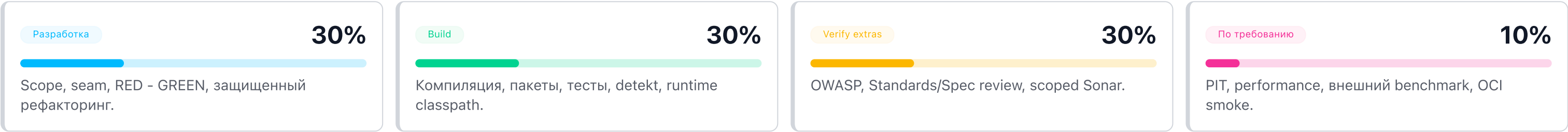


# Проверки и контроль кода

Единая карта от TDD-среза до post-issue verification. Вес показывает долю элемента в общей уверенности в изменении, а не длительность запуска и не вероятность дефекта.

Ключевая поправка  
build включает detekt, но не pitest. PIT запускается отдельно.



## Что реально запускает каждый контур

Одинаковая проверка при повторном запуске дает свежее подтверждение, но не получает второй процентный вес.

| Момент                   | Команда / механизм                                      | Состав                                                  | Роль                      |
|--------------------------|---------------------------------------------------------|---------------------------------------------------------|---------------------------|
| Каждый TDD-срез          | ./gradlew test --tests ...                              | Один RED, минимальный GREEN, повтор того же теста       | быстрая обратная связь    |
| Финиш реализации         | ./gradlew build                                         | Компиляция + assemble + test + detekt + classpath check | обязательный gate         |
| Pre-push                 | config/git/hooks/pre-push                               | Тот же ./gradlew build                                  | не пустить сломанный push |
| CI                       | .github/workflows/ci.yml                                | build; отдельно OWASP, только если доступен NVD_API_KEY | независимая среда         |
| verify-changes, шаги 1-2 | scripts/pipeline-verify                                 | build, затем verifyAll = build + dependencyCheckAnalyze | механические gates        |
| verify-changes, шаг 3    | two-axis-review                                         | Standards и Spec независимо, параллельно                | LLM judgement             |
| verify-changes, шаг 4    | scripts/pipeline-sonar                                  | test + JaCoCo + Sonar API + фильтр по touched files     | scoped static gate        |
| Глубокая проверка        | pitest, perfTest, piiJmhBaseline, benchmarks, OCI smoke | Выбирается по риску и типу изменения                    | не входит в verify        |

## Найденные расхождения в документации

- Комментарий pre-push говорит, что verifyAll включает mutation testing. Реальный task graph: только build + dependencyCheckAnalyze.
- README говорит, что CI запускает PIT. Фактический .github/workflows/ci.yml: build и условный OWASP job, без PIT.
- pipeline-verify сначала запускает build, затем verifyAll, который снова зависит от build. Обычно второй проход UP-TO-DATE и не является отдельной проверкой.

## Как читать проценты

Это рекомендуемая экспертная модель: severity предотвращаемого ущерба x уникальность класса дефектов x ранность обратной связи. Вес родителей равен сумме дочерних строк. Повтор одного и того же теста в TDD, build, pre-push и CI повышает свежесть доказательства, но не создает новый класс контроля и потому не суммируется повторно.

Источники: CLAUDE.md, README.md, build.gradle.kts, scripts/pipeline-verify, scripts/pipeline-sonar, config/git/hooks/pre-push, .github/workflows/ci.yml, skills verify-changes, two-axis-review, tdd, analyze-pitest.

# Атомарная таблица контроля

Только строки-листья имеют вес. Сумма всех строк - 100%.

100% assurance budget

| #     | Контур     | Элемент                                 | Где / чем                                                           | Что дает                                                                                                                          | Чего не доказывает                                                         | Важность                  |
|-------|------------|-----------------------------------------|---------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|---------------------------|
| 1     | Разработка | Источник задачи и границы               | Issue/spec, включая «Не входит»                                     | Не дает построить качественно неверную или лишнюю функциональность.                                                               | Не подтверждает корректность кода.                                         | <div><div></div></div> 6% |
| 2     | Разработка | Согласованный seam                      | Публичная граница теста из issue/guide либо явное согласование      | Удерживает тесты на наблюдаемом поведении, делает их устойчивыми к рефакторингу.                                                  | Сам по себе не находит дефект.                                             | <div><div></div></div> 4% |
| 3     | Разработка | RED-тест                                | Один focused behavior/regression test до production code            | Доказывает, что тест способен увидеть требуемое поведение или воспроизвести баг.                                                  | Не доказывает полноту покрытия.                                            | <div><div></div></div> 8% |
| 4     | Разработка | Минимальный GREEN                       | Тот же focused test после минимальной реализации                    | Короткая причинная связь между требованием, тестом и кодом; сдерживает speculative generality.                                    | Не ловит регрессии за пределами среза.                                     | <div><div></div></div> 6% |
| 5     | Разработка | Рефакторинг под GREEN                   | Existing GREEN tests + финальный affected suite                     | Позволяет улучшать структуру без незаметной смены поведения.                                                                      | Не заменяет независимое review.                                            | <div><div></div></div> 4% |
| 6     | Разработка | Самоконтроль инвариантов                | CLAUDE.md: KDoc, streaming, event-loop, logging, YAGNI/SOLID        | Предотвращает нарушения архитектурных и эксплуатационных ограничений до review.                                                   | Зависит от дисциплины автора.                                              | <div><div></div></div> 2% |
| 7     | Build      | Компиляция и warnings-as-errors         | compileKotlin, compileJava, plugin config                           | Ловит ошибки типов, несовместимые API и Kotlin warnings; фиксирует JVM 25 contract.                                               | Не подтверждает runtime-поведение.                                         | <div><div></div></div> 6% |
| 8     | Build      | Assemble и дистрибутив                  | jar, start scripts, distTar, distZip                                | Проверяет, что production-артефакты и скрипты запуска вообще собираются.                                                          | Не запускает готовый контейнер.                                            | <div><div></div></div> 1% |
| 9     | Build      | Unit, contract, property и corpus tests | test, включая Java contracts и canonical PII gate                   | Проверяет доменную логику, edge cases, checksums, совместимость публичных контрактов и качество PII на фиксированном corpus.      | Не доказывает работу полного gateway path для каждого сценария.            | <div><div></div></div> 8% |
| 10    | Build      | E2E / integration tests                 | test, реальные Armeria servers и ephemeral ports                    | Ловит ошибки wiring, HTTP semantics, streaming, cancellation, health, telemetry и конфигурации так, как их видит клиент.          | Не является нагрузочным или production-container тестом.                   | <div><div></div></div> 8% |
| 11    | Build      | Detekt                                  | detekt, default rules + project config                              | Механически ловит Kotlin code smells, сложность, рискованные конструкции и нарушения style rules.                                 | Не сверяет бизнес-требования и не заменяет Sonar/ревью.                    | <div><div></div></div> 5% |
| 12    | Build      | Production classpath guard              | piiProductionRuntimeClasspathCheck через check                      | Не дает JMH/benchmark-зависимостям попасть в shipped runtime classpath.                                                           | Не сканирует CVE и не меряет размер артефакта.                             | <div><div></div></div> 2% |
| 13    | Verify 0   | Единый verification scope               | merge-base/dirty tree + полный источник задачи                      | Гарантирует, что механика, review и Sonar проверяют один и тот же diff.                                                           | Не оценивает качество изменений.                                           | <div><div></div></div> 2% |
| 14    | Verify 2   | OWASP Dependency-Check                  | dependencyCheckAnalyze, только runtimeClasspath, threshold CVSS 9.0 | Блокирует известные Critical CVE в поставляемых зависимостях; сохраняет отчет и обоснованные suppressions.                        | Не ищет source-code уязвимости; CVSS ниже 9.0 не блокирует.                | <div><div></div></div> 7% |
| 15    | Verify 3   | Standards: жесткие правила              | Независимая Standards-ось                                           | Находит нарушения documented standards, KDoc и архитектурных constraints, которые не принуждаются tooling.                        | Не сверяет полноту реализации issue.                                       | <div><div></div></div> 5% |
| 16    | Verify 3   | Standards: Fowler smells                | Mysterious Name, Duplication, Feature Envy и др.                    | Подсвечивает структурный долг и неудачные границы, которые формальные линтеры часто пропускают.                                   | Это judgement call, не автоматический defect verdict.                      | <div><div></div></div> 2% |
| 17    | Verify 3   | Спец-ось                                | Criteria matrix + «Не входит» + gold-plating + unrelated work       | Проверяет полноту, точность и границы результата; не дает хорошему коду решить не ту задачу.                                      | Статически не доказывает runtime/SLO без соответствующего теста.           | <div><div></div></div> 7% |
| 18    | Verify 4   | Test + JaCoCo input                     | test jacocoTestReport sonar                                         | Дает Sonar актуальные результаты тестов и XML-покрытие для анализа.                                                               | Coverage не является blocking scoped verdict сам по себе.                  | <div><div></div></div> 1% |
| 19    | Verify 4   | Sonar issues                            | Bugs, vulnerabilities, code smells только в touched files           | Ловит межправильные source-level проблемы и блокирует находки текущего изменения.                                                 | Находки baseline вне score не блокируют issue.                             | <div><div></div></div> 3% |
| 20    | Verify 4   | Sonar security hotspots                 | Отдельный API, фильтр по touched files                              | Выносит security-sensitive код на обязательное рассмотрение, даже когда это не подтвержденная vulnerability.                      | Hotspot требует человеческой оценки контекста.                             | <div><div></div></div> 2% |
| 21    | Verify 4   | Sonar measures / quality gate           | Coverage, duplication, ratings, whole-project gate                  | Дает тренд и контекст общего качества; помогает видеть baseline-техдолг.                                                          | В текущем pipeline это информационные данные, не scoped blocker.           | <div><div></div></div> 1% |
| 22    | Отдельно   | PIT mutation testing                    | ./gradlew pitest + классификация SURVIVED/NO_COVERAGE               | Проверяет не факт выполнения строк, а чувствительность тестов к смысловым изменениям; находит слабые assertions и непокрытый код. | Медленный, Kotlin дает шум; не входит в build/verifyAll/verify-changes/CI. | <div><div></div></div> 6% |
| 23    | Отдельно   | PERF-01                                 | perfContractTest + perfTest / Gatling                               | Проверяет сценарий нагрузки и overhead gateway относительно direct baseline на 2 000 RPS.                                         | Не входит в обычные gates; нужен для performance-sensitive изменений.      | <div><div></div></div> 1% |
| 24    | Отдельно   | PII JMH baseline                        | piiJmhBaseline                                                      | Сравнимо измеряет p50/p95/p99 детектора на 108 комбинациях и фиксирует окружение.                                                 | Сейчас не имеет числового release gate.                                    | <div><div></div></div> 1% |
| 25    | Отдельно   | External PII benchmark                  | redMadRobotPiiBenchmark                                             | Дает независимое внешнее свидетельство precision/recall за пределами synthetic corpus.                                            | Non-gating; зависит от pinned dataset и методики адаптера.                 | <div><div></div></div> 1% |
| 26    | Отдельно   | OCI smoke                               | scripts/oci-smoke-test                                              | Проверяет реальный образ: non-root, env/file config, read-only mount, health, proxy, invalid config и SIGTERM.                    | Не входит в build, verify или CI.                                          | <div><div></div></div> 1% |
| Итого |            |                                         |                                                                     |                                                                                                                                   |                                                                            | 100%                      |